

CHECKPOINT 01

Ferramentas open source no pipeline DevSecOps

Semgrep | OWASP Dependency Check | Checkov | OWASP ZAP

Grupo 4 · Turma 2TDCPF

Professor Fabio Pires

Equipe e responsabilidades

Tiago Louzã

Líder técnico e responsável pelo repositório

Erik Gunnar · RM565107

Relator

Leando de Souza Silva · RM566485

Luiz Fernando · RM562652

Fabricio de Freitas Evangelista · RM564782

Repositório

github.com/TiagoLouzaPetagna/grupo4-devsecops

Agenda e distribuição do tempo

03 min Fundamentos e posição no pipeline

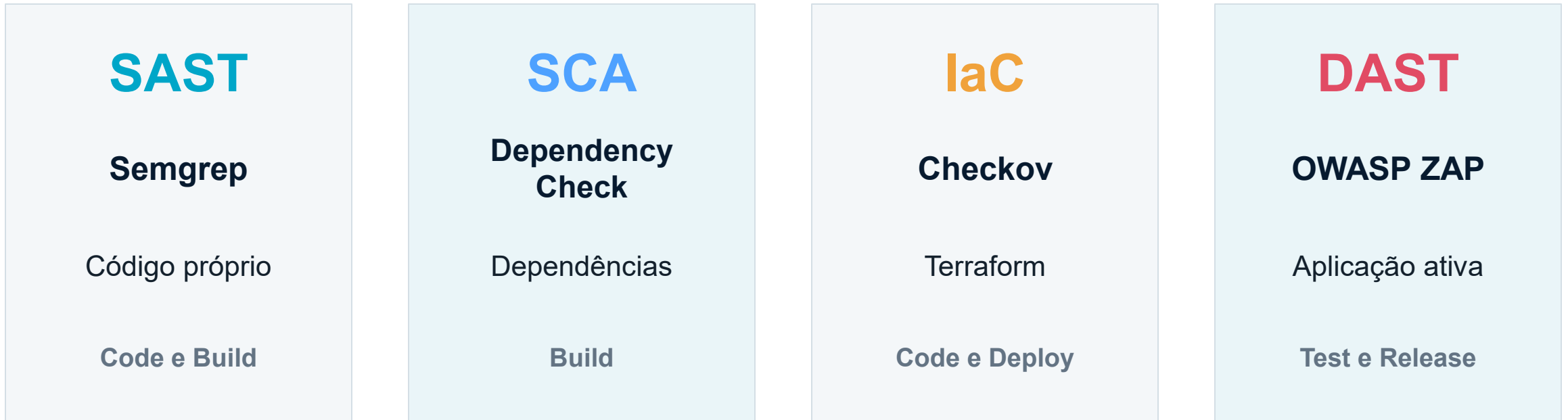
10 min Semgrep, Dependency Check, Checkov e ZAP

12 min Laboratório guiado com Semgrep e ZAP

03 min Comparação, limitações e conclusão

02 min Perguntas

Quatro frentes complementares



Cada ferramenta responde a uma pergunta diferente e preserva uma evidência diferente.

SAST, SCA e o limite do shift left

SAST

Procura padrões inseguros no código que a equipe escreveu.

Correção típica: alterar a implementação.

SCA

Constrói o inventário de componentes e correlaciona versões com CVEs.

Correção típica: atualizar, substituir ou mitigar.

Shift left antecipa o feedback, mas não enxerga o comportamento final da aplicação.

O ZAP permanece necessário para observar rotas, cabeçalhos, sessões e configurações em execução.

Metodologia e escopo autorizado

OWASP Juice Shop v20.2.0

- Código e imagem oficial na mesma versão
- Aplicação publicada somente em 127.0.0.1:3000
- Rede interna do Docker Compose
- Dados sintéticos da aplicação de treinamento

Escopo ético

- Nenhuma varredura em site público
- Nenhum sistema corporativo ou de terceiros
- Active scan limitado por tempo e por regras
- Relatórios preservados para auditoria

Alvo autorizado e isolado

Semgrep

O que analisa

- AST e padrões estruturais
- Metavariáveis e regras específicas
- Taint analysis em modos compatíveis

Uso no laboratório

- Scan geral com --config auto
- Regra local para o red e green
- JSON processado pelo quality gate

Ponto forte

Feedback rápido e regras legíveis

Limitação

Cobertura e ruído dependem das regras e do contexto

Scan geral do Semgrep

```
>> semgrep scan `
>> --config auto `
>> --json
>> --output /src/reports/semgrep-auto.json `
>> /src/target/juice-shop 2>&1 |
>> Tee-Object ".\reports\semgrep-auto-live.log"
docker :
No linha:1 caractere:1
+ docker run --rm `
+ #####
+ CategoryInfo          : NotSpecified: (          :String) [], RemoteException
+ FullyQualifiedErrorId : NativeCommandError

Scan Status

Scanning 1027 files tracked by git with 1074 Code rules:

Language    Rules    Files    Origin    Rules
-----
<multilang> 77       685     Community 1074
ts           163      507
json         4        105
yaml         35       98
html         1        82
solidity     21       17
js           153      12
terraform    101      11
dockerfile   6         2
bash         4         1

Scan Summary

✔ Scan completed successfully.
• Findings: 69 (69 blocking)
• Rules run: 408
• Targets scanned: 1027
• Parsed lines: ~99.9%
• Scan skipped:
  • Files larger than 1.0 MB: 2
  • Files matching .semgrepignore patterns: 7
• For a detailed list of skipped files and lines, run semgrep with the --verbose flag
Ran 408 rules on 1027 files: 69 findings.
A new version of Semgrep is available. See https://semgrep.dev/docs/upgrading
🚩 Too many findings? Try Semgrep Pro for more powerful queries and less noise.
See https://sg.run/false-positives.
```

1.027

ARQUIVOS

408

REGRAS EXECUTADAS

69

ACHADOS

O scan geral usou --config auto. Nenhuma regra do grupo foi necessária para encontrar SQL Injection.

Cenário SAST red

```
Network grupo4-devsecops_default Creating
Network grupo4-devsecops_default Creating
Network grupo4-devsecops_default Created
Network grupo4-devsecops_default Created
Container grupo4-devsecops-semgrep-run-bad56ae321d0 Creating
Container grupo4-devsecops-semgrep-run-bad56ae321d0 Created



Scan Status



Scanning 1 file tracked by git with 3 Code rules:



Scanning 1 file with 3 ts rules.



Scan Summary



✅ Scan completed successfully.



- Findings: 1 (1 blocking)
- Rules run: 3
- Targets scanned: 1
- Parsed lines: ~100.0%
- No ignore information available



Ran 3 rules on 1 file: 1 finding.



A new version of Semgrep is available. See https://semgrep.dev/docs/upgrading



Container grupo4-devsecops-gate-run-d35ff5c31c79 Creating



Container grupo4-devsecops-gate-run-d35ff5c31c79 Created



Gate DevSecOps – limiar: HIGH



Achados totais: 1 | Bloqueadores: 1



- [HIGH] Semgrep security.juice-shop.typescript.sql-injection – Query SQL construída com interpolação de template. Use parâmetros/replacements do Sequelize para separar dados da instrução SQL. (/workspace/target/juice-shop/routes/search.ts:23)



SUCESSO DO TESTE: o gate bloqueou o cenário vulnerável como esperado.


```

1 HIGH

CWE-89

Interpolação dentro de
sequelize.query em
routes/search.ts:23

Gate bloqueado

Correção de SQL Injection

Antes

```
sequelize.query(`SELECT * FROM  
Products  
WHERE name LIKE '%${criteria}%'  
OR description LIKE  
'%${criteria}%'`)
```

Depois

```
sequelize.query(`SELECT * FROM  
Products  
WHERE name LIKE :criteria  
OR description LIKE :criteria`,  
{ replacements: { criteria:  
`%${criteria}%` } })
```

A parametrização impede que o valor altere a estrutura da consulta.

Cenário SAST green

Container grupo4-devsecops-semgrep-run-d209d379531b Creating
Container grupo4-devsecops-semgrep-run-d209d379531b Created

Scan Status

Scanning 1 file tracked by git with 3 Code rules:
Scanning 1 file with 3 ts rules.

Scan Summary

✅ Scan completed successfully.
• Findings: 0 (0 blocking)
• Rules run: 3
• Targets scanned: 1
• Parsed lines: ~100.0%
• No ignore information available
Ran 3 rules on 1 file: 0 findings.

A new version of Semgrep is available. See <https://semgrep.dev/docs/upgrading>
If Semgrep missed a finding, please send us feedback to let us know!
See <https://semgrep.dev/docs/reporting-false-negatives/>
Container grupo4-devsecops-gate-run-2aa277bc1824 Creating
Container grupo4-devsecops-gate-run-2aa277bc1824 Created

Gate DevSecOps – limiar HIGH
Achados totais: 0 | Bloqueadores: 0
GATE APROVADO: nenhum HIGH/CRITICAL nos relatórios informados.

0

HIGH ou CRITICAL

Gate aprovado

O resultado valida esse recorte.
Ele não afirma que todo o Juice
Shop ficou seguro.

OWASP Dependency Check

Técnica

- Coleta evidências de nome e versão
- Tenta associar componentes a CPEs
- Consulta vulnerabilidades conhecidas

Condições para um bom resultado

- Lockfiles presentes
- Dependências resolvidas
- Base NVD atualizada e cacheada
- Supressões justificadas

Um relatório com zero CVEs pode continuar inconclusivo quando o inventário está incompleto.

Resultado inconclusivo do SCA



DEPENDENCY-CHECK

Dependency-Check is an open source tool performing a best effort analysis of 3rd party dependencies; false positives and false negatives may exist in the analysis performed by the tool. Use of the tool and the reporting provided constitutes acceptance for use in an AS IS condition, and there are NO warranties, implied or otherwise, with regard to the analysis or its use. Any use of the tool and the reporting provided is at the user's risk. In no event shall the copyright holder or OWASP be held liable for any damages whatsoever arising out of or in connection with the use of this tool, the analysis performed, or the resulting report.

[How to read the report](#) | [Suppressing false positives](#) | [Getting Help: github issues](#)

Project: Checkpoint DevSecOps Grupo 4

Scan Information ([show all](#)):

- *dependency-check version:* 13.0.0
- *Report Generated On:* Wed, 16 Sep 2026 00:38:03 GMT
- *Dependencies Scanned:* 15 (15 unique)
- *Vulnerable Dependencies:* 0
- *Vulnerabilities Found:* 0
- *Vulnerabilities Suppressed:* 0
- ...

Analysis Exceptions

java.util.zip.ZipException: encrypted ZIP entry not supported

Archive contains a file (../frontend/dist/frontend/assets/public/videos/owasp_promo.vtt) that would be extracted outside of the target directory.

Archive contains a file (../ftp/legal.md) that would be extracted outside of the target directory.

java.io.EOFException: Expected to read bytes from the stream

Summary

Summary of Vulnerable Dependencies ([click to show all](#))

Dependency	Vulnerability IDs	Package	Highest Severity	CVE Count	Confidence	Evidence Count
------------	-------------------	---------	------------------	-----------	------------	----------------

Dependencies (vulnerable)

This report contains data retrieved from the [National Vulnerability Database](#).
This report may contain data retrieved from the [CISA Known Exploited Vulnerability Catalog](#).
This report may contain data retrieved from the [GitHub Advisory Database \(via NPM Audit API\)](#).
This report may contain data retrieved from [RetireJS](#).
This report may contain data retrieved from the [Sonatype Guide OSS Index API](#).

15

DEPENDÊNCIAS

0

CVES REPORTADAS

4

EXCEÇÕES

Faltaram package-lock.json e node_modules. A ferramenta alertou para possíveis falsos negativos.

Checkov

O que faz

- Interpreta arquivos declarativos
- Aplica políticas nativas ou próprias
- Analisa atributos e relações em grafo

Execução do grupo

- Terraform oficial do Juice Shop
- Políticas nativas
- Sem regra criada pelo grupo
- Saídas CLI, JSON e SARIF

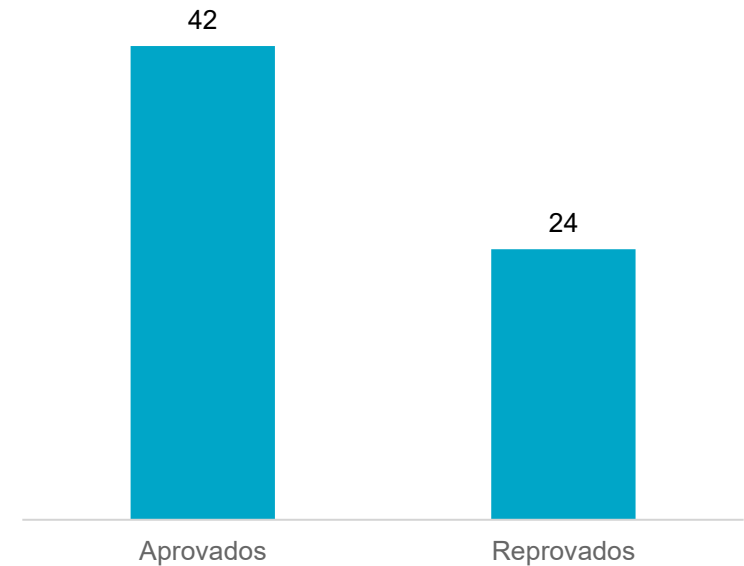
A ferramenta identifica desvios de política. O contexto do ambiente ainda exige triagem humana.

Resultado do Checkov

```
PS C:\Users\Hayom\Documents\CheckpointDevOps> docker run --rm `
>> -v "${ProjectDir}\target\juice-shop\terraform:tf:ro" `
>> ghcr.io/bridgecrewio/checkov:3.3.11 `
>> -d /tf `
>> --framework terraform `
>> --quiet `
>> --compact `
>> --soft-fail 2>&1 |
>> Tee-Object ".\reports\checkov-live.log"
terraform scan results:

Passed checks: 42, Failed checks: 24, Skipped checks: 0

Check: CKV_AWS_336: "Ensure ECS containers are limited to read-only access to root filesystems"
  FAILED for resource: aws_ecs_task_definition.juice_shop
  File: /main.tf:35-97
  Guide: https://docs.prismacloud.io/en/enterprise-edition/policy-reference/aws-policies/aws-general-policies/bc-aws-336
Check: CKV_AWS_333: "Ensure ECS services do not have public IP addresses assigned to them automatically"
  FAILED for resource: aws_ecs_service.juice_shop
  File: /main.tf:99-124
  Guide: https://docs.prismacloud.io/en/enterprise-edition/policy-reference/aws-policies/aws-logging-policies/bc-aws-333
Check: CKV_AWS_338: "Ensure CloudWatch log groups retains logs for at least 1 year"
  FAILED for resource: aws_cloudwatch_log_group.juice_shop
```



66 verificações em 26 recursos

Nenhum erro de parsing

Falhas priorizadas do Checkov

Check	Condição	Tratamento
CKV_AWS_333	ECS com IP público	Sub-rede privada
CKV_AWS_260	Porta 80 aberta para todos	Restringir ou redirecionar
CKV_AWS_2	Listener HTTP	HTTPS com certificado
CKV_AWS_91	Logs do ALB ausentes	Habilitar access logs
CKV2_AWS_11	VPC flow logs ausentes	Habilitar flow logs
CKV2_AWS_28	ALB público sem WAF	Associar Web ACL

Os seis itens foram confirmados no Terraform. Os outros 18 não receberam triagem manual completa.

OWASP ZAP

Plano automatizado

- Spider tradicional
- AJAX spider
- Passive scan
- Active scan de XSS e SQL Injection

Configuração do grupo

- Plano YAML de execução
- Regras nativas 40012 e 40018
- Limite de quatro minutos
- Relatórios HTML, JSON e SARIF

O YAML organiza o scan. Ele não cria uma nova regra de detecção.

Execução dinâmica do ZAP

```
Job activeScan finished, time taken: 00:03:48
Job passiveScan-wait started
Job passiveScan-wait finished, time taken: 00:00:00
Job report started
Job report generated report /zap/wrk/reports/zap-juice-shop.html
Job report finished, time taken: 00:00:02
Job report started
Job report generated report /zap/wrk/reports/zap-juice-shop.json
Job report finished, time taken: 00:00:00
Job report started
Job report generated report /zap/wrk/reports/zap-juice-shop.sarif.json
Job report finished, time taken: 00:00:01
Job exitStatus started
An alert has been raised with a risk of at least: Medium
Job exitStatus finished, time taken: 00:00:00
Automation plan failures:
  An alert has been raised with a risk of at least: High
Automation plan warnings:
  An alert has been raised with a risk of at least: Medium
An alert has been raised with a risk of at least: High

Network grupo4-devsecops_default Creating
Network grupo4-devsecops_default Creating
Network grupo4-devsecops_default Created
Network grupo4-devsecops_default Created
Container grupo4-devsecops-gate-run-ce32c133cf63 Creating
Container grupo4-devsecops-gate-run-ce32c133cf63 Created

Gate DevSecOps - limiar HIGH
Achados totais: 11 | Bloqueadores: 1
- [HIGH] OWASP ZAP 40018 - SQL Injection (http://juice-shop:3000)
SUCESSO DO TESTE: o gate bloqueou o cenário vulnerável como esperado.
Container grupo4-devsecops-juice-shop-1 Stopping
Container grupo4-devsecops-juice-shop-1 Stopped
Container grupo4-devsecops-juice-shop-1 Removing
Container grupo4-devsecops-juice-shop-1 Removed
Network grupo4-devsecops_default Removing
Network grupo4-devsecops_isolated-lab Removing
Network grupo4-devsecops_default Removed
Network grupo4-devsecops_isolated-lab Removed
```

101

URLS SPIDER

234

URLS AJAX

3:48

ACTIVE SCAN

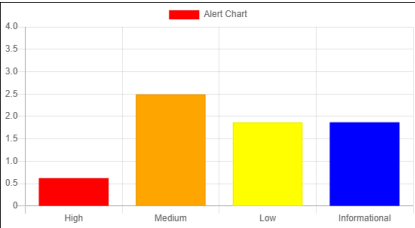
Alvo: contêiner local

Alertas do OWASP ZAP



Grupo 4 — OWASP ZAP em Juice Shop v20.2.0

Generated on Wed, 16 Sept 2026 00:46:13
ZAP Version: 2.17.0
ZAP by [Checkmarx](#)

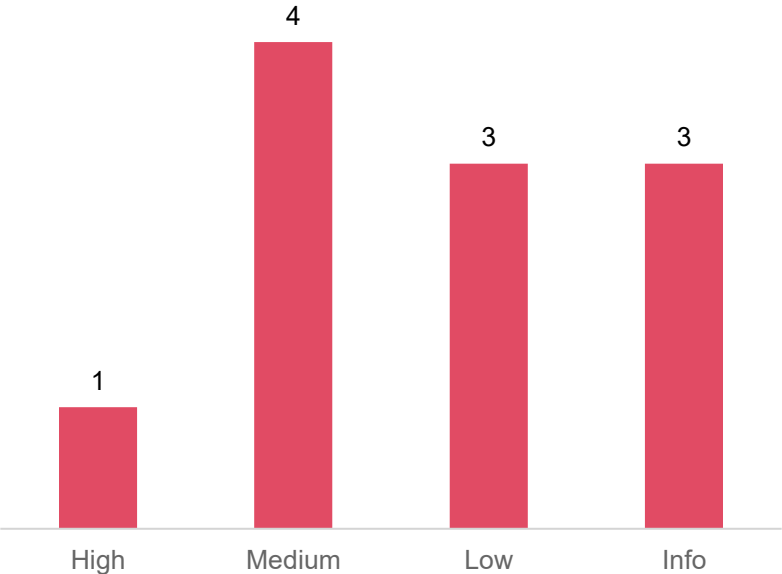


Summary of Alerts

Risk Level	Number of Alerts
High	1
Medium	4
Low	3
Informational	3
False Positives	0

Insights

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP errors logged - see the zap.log file for details	281
Low	Warning		ZAP warnings logged - see the zap.log file for details	5
Low	Exceeded Low		Percentage of network failures	5 %
Info	Informational	http://juice-shop:3000	Percentage of responses with status code 1xx	1 %
Info	Informational	http://juice-shop:3000	Percentage of responses with status code 2xx	55 %
Info	Informational	http://juice-shop:3000	Percentage of responses with status code 3xx	28 %
Info	Informational	http://juice-shop:3000	Percentage of responses with status code 4xx	14 %
Info	Informational	http://juice-shop:3000	Percentage of responses with status code 5xx	1 %
Info	Informational	http://juice-shop:3000	Percentage of endpoints with content type application/javascript	8 %
Info	Informational	http://juice-shop:3000	Percentage of endpoints with content type application/json	8 %
Info	Informational	http://juice-shop:3000	Percentage of endpoints with content type application/octet-stream	4 %
Info	Informational	http://juice-shop:3000	Percentage of endpoints with content type font/woff2	1 %
Info	Informational	http://juice-shop:3000	Percentage of endpoints with content type image/png	11 %
Info	Informational	http://juice-shop:3000	Percentage of endpoints with content type image/png	5 %
Info	Informational	http://juice-shop:3000	Percentage of endpoints with content type image/x-icon	1 %



11 tipos de alerta · 39 instâncias

SQL Injection HIGH · plugin 40018

Fluxo do laboratório de 12 minutos



A turma executa somente três comandos. Os comandos extensos ficam dentro dos scripts.

Comandos digitados pela turma

01

```
.\scripts\run-lab.ps1 -Mode sast-red
```

02

```
.\scripts\run-lab.ps1 -Mode sast-green
```

03

```
.\scripts\run-lab.ps1 -Mode dast
```

Perguntas de verificação

1. Quantos HIGH aparecem no Semgrep red?
2. Qual plugin do ZAP reporta a SQL Injection e qual é o CWE?

Pipeline e demonstração red/green

Cenário red

- Escaneia o arquivo vulnerável
- Reprocessa o JSON com expectativa de aprovação
- A Action falha por encontrar HIGH

Cenário green

- Cria a cópia parametrizada
- Repete a mesma regra
- A Action termina sem bloqueadores

Workflow manual

`.github/workflows/red-green-demo.yml`

Workflow principal

Semgrep e OWASP ZAP integrados

Três achados analisados

Achado	Ferramenta	Classificação	CWE	Tratamento
SQL Injection na busca	Semgrep e ZAP	VP	CWE-89	Consulta parametrizada
Listener HTTP no ALB	Checkov	VP	CWE-319	HTTPS e redirecionamento
SQLi em codefix didático	Semgrep	FP operacional	CWE-89	Excluir somente o caminho

A classificação depende do alcance real do artefato, da evidência independente e da possibilidade de reprodução.

Falso positivo operacional não significa que a regra está errada. O contexto muda a decisão do gate.

Comparação do toolchain

Critério	Semgrep	Dependency Check	Checkov	OWASP ZAP
Entrada	Código	Dependências	IaC	Aplicação ativa
Tempo	~3 min	7 s	~9 s	~4 min 48 s
Resultado	69 geral	0 CVEs, inconclusivo	42 pass, 24 fail	11 tipos, 1 High
Limitação	Ruído	Inventário	Contexto	Cobertura

Recomendação do Grupo 4

**Semgrep e Checkov em pull requests. Dependency Check depois da resolução das dependências.
ZAP em ambiente efêmero de teste.**

Limitações e conclusão

- Somente recortes prioritários dos 69 achados do Semgrep receberam triagem
- O Dependency Check analisou um inventário incompleto
- O Checkov avaliou código Terraform, não recursos implantados
- O ZAP não autenticou usuários e atingiu o limite do active scan

Conclusão

A combinação das quatro ferramentas amplia a cobertura porque código, dependências, infraestrutura e comportamento exigem evidências diferentes.

Gates precisam registrar cobertura, confiança e exceções. Severidade isolada não substitui triagem.

Defesa em profundidade com critérios explícitos

Referências e perguntas

Fontes principais

- NIST SP 800-218 Secure Software Development Framework
- OWASP DevSecOps Guideline
- OWASP Top 10 A03 Injection
- Semgrep Documentation and Repository
- OWASP Dependency Check Documentation
- Checkov Documentation and Repository
- OWASP ZAP Automation Framework
- OWASP Juice Shop v20.2.0
- MITRE CWE-89 and CWE-319
- CISA Minimum Elements for an SBOM

Perguntas?

Relatório, laboratório e evidências no repositório do
Grupo 4